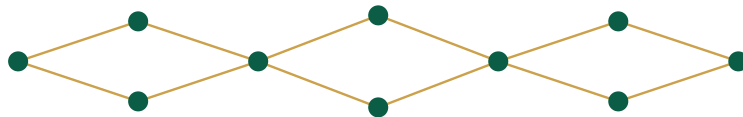


SAIF · KINGDOM OF SAUDI ARABIA

SANDOOQ

Dana Alharbi

Sovereign, end to end encrypted cloud storage, owned by the
people who use it.



1. The problem

I ran out of storage again.

There are only ever two options on the screen: delete photos I actually want, or pay for more space. I have chosen "pay" so many times that I stopped counting. And then one question started bothering me and would not go away. Why am I renting room on a computer I will never see, when I already own storage that sits there doing nothing?

That question became this project. Storage is the only utility that becomes more expensive the longer you depend on it. Every phone ships with exactly enough space to create demand, and the only remedy offered is a subscription that never ends. This is not a personal annoyance. It is a global structure that quietly moved the world's personal data onto someone else's balance sheet, and it did so while making renting feel normal.

1.1 Three stacked problems

1. **The capacity trap.** Your device fills up, and the paid upgrade is positioned as the only answer.
2. **The ownership gap.** You pay for the storage, but you never own it, and you can never switch it off.
3. **The sovereignty gap.** Your files are copied to data centres in America and other countries, under laws you never agreed to.

1.2 What actually happens to your files

Conventional cloud

- Files are copied to foreign data centres.
- The provider holds the encryption keys, so it can technically read everything.
- Privacy is a policy that can be rewritten overnight, not a fact you can test.
- You cannot audit who has access or where copies exist.
- Legal authority over your data sits in a foreign jurisdiction.
- Each month, the payment leaves the country permanently.

Sandooq

- Files are cryptographically sealed on the user's own device before they move.
- The operator never holds a key, so it cannot read anything, at any point.
- Privacy is mathematics, and mathematics does not change its mind.
- Anyone can verify it: the storage disk shows unreadable blocks only.
- Saudi data stays under Saudi rules, inside the Kingdom.
- Each month, the payment becomes income for a host inside the country.

1.3 The invisible half: wasted capacity

While millions of people pay for storage, millions more already own storage they never use. Old laptops, external drives and NAS boxes sit idle in homes, schools and small offices across the Kingdom, producing nothing, because there has never been a safe and simple way to share them or to earn from them. That unused capacity is the raw material of this project.

2. The solution

Sandooq is a self hosted, end to end encrypted cloud platform combined with a marketplace for storage, and administered over a private encrypted network instead of an exposed one.

- **It gives users sovereign storage.** Encrypted on the device, stored in the Kingdom, verifiable by the user, reachable from any device.
- **It turns idle hardware into income.** Anyone with spare capacity can run a node and earn monthly revenue from the space they are not using.

- **It keeps its own doors shut.** Administration, federation and backups run inside a private Tailscale network, so the public internet sees one service and nothing else.

The design principle: zero trust toward the operator. The system is built so that the company running it, me included, cannot read user files. Privacy is not a promise here, it is an architectural constraint.

3. The technology, in full detail

3.1 The applications used

Application	Role in the project
Tailscale	The private access layer. It builds a WireGuard based tailnet between the public node, the private node and the operator's devices, giving each a stable 100.x.y.z address. This is what lets the server close its SSH port and what makes the home node reachable from anywhere.
Termius (iPhone and Mac)	The secure terminal client. It connects over the tailnet, or over the custom SSH port 52156 when needed.
macOS Terminal + ssh-keygen	Generates the Ed25519 key pair. The private key never leaves the device, and only the public key is shared with the server.
Apple Files app	The native file browser on iOS, used as the destination for the storage nodes through SMB and through file provider extensions.
Samba (SMB)	The file sharing protocol used by the private node, reachable over the tailnet from any network.
Cryptomator (iPhone, macOS)	Creates the encrypted vault. Files are encrypted on the device before upload, so every node stores blocks it cannot read.
Nextcloud or Seafile	The cloud platform on the public node: user accounts, quotas, sharing, mobile apps, a web interface and federation.
Secure ShellFish or Owlfiles	File provider applications that bring SFTP storage into the native Files app, without giving up the SSH key model.
Let's Encrypt	Provides the free TLS certificate that gives the public node a trusted HTTPS connection.
Docker or snap	Packaging and deployment of the cloud platform on the node, in a repeatable, isolated way.

3.2 The protocols and ports

Protocol	Purpose	Exposure
Tailscale / WireGuard	Private encrypted network for nodes, operators and invited testers	private, device authenticated
HTTPS / TLS	Serves real users and proves the identity of the platform	public, port 443
SSH	Administration and transfer	inside the tailnet only
SFTP	Encrypted file transfer using the same keys	inside SSH
SMB	File sharing for the private node and the iPhone Files app	tailnet or LAN only
AFP	Apple's retired file protocol, deliberately not used	deprecated
WebDAV	Web based file access for compatible applications	behind HTTPS
DNS	Resolves the domain name to the public node	public

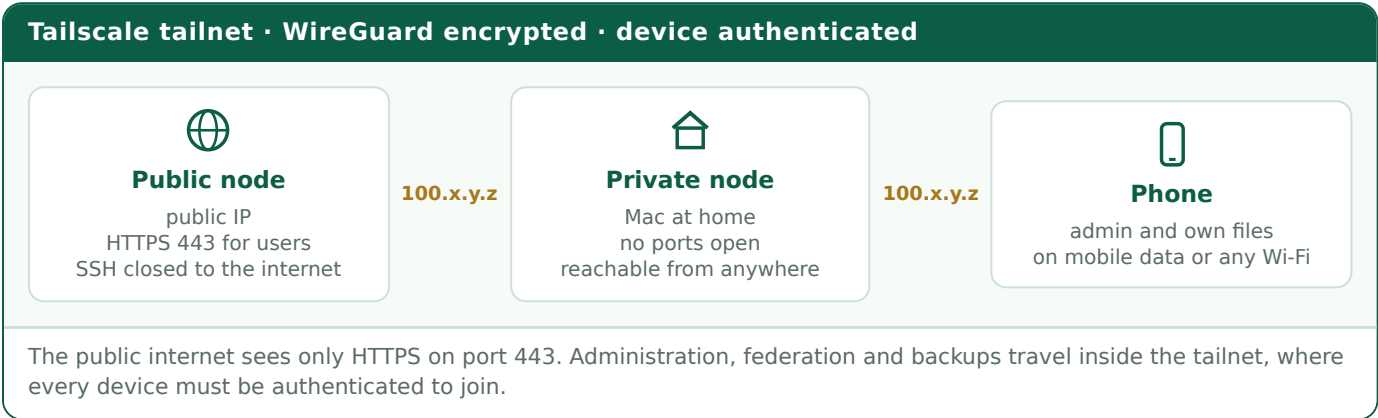
3.3 The layers of protection

Layer	What it protects	How it is achieved
Network access	Who can even reach a port	Tailscale tailnet with WireGuard, device authentication and access rules
In transit	Data while it is moving	HTTPS and TLS for users, SSH or WireGuard for operators
At rest	Data while it sits on a disk	Full disk encryption on the node, plus the encrypted vault itself
End to end	Data from everyone, including the operator	Cryptomator vaults, where the key is created on the user's device and never transmitted

4. Security architecture: two nodes, one private network

The proof of concept runs on two nodes on purpose, because each one proves something different.

Node	What it is	How it is exposed
Public node	A rented server with a public IP address	HTTPS on port 443 for real users. SSH is not exposed to the internet.
Private node	A Mac at home	No public address at all. Before Tailscale it worked only when the phone was on the same Wi-Fi.



4.1 What Tailscale changes

- **Smaller attack surface.** The server's SSH port can be closed to the entire internet, so automated scanners and credential attacks have nothing to reach. This is a measurable security improvement, not a feeling.
- **The private node becomes useful.** The Mac at home is now reachable from the phone or from the server, from another city or on mobile data, with no ports opened on the home router and no public address. It stops being a Wi-Fi only experiment and becomes a real second node.
- **Federation becomes real.** Two nodes on one private network can federate and back each other up over the tailnet, which turns the decentralisation claim into something that can be demonstrated rather than drawn.
- **Private beta access.** Testers can be invited into the tailnet and use the service without any public exposure, which is exactly what a first pilot needs.
- **Identity, not just secrecy.** Every device is authenticated before it joins, access rules can be written per device, and devices can be removed instantly if one is lost.

4.2 Two different layers, both required

	Tailscale	Cryptomator
Protects	The network path, and who can reach a port	The contents of the files themselves
Stops	Scanners, unwanted connections, exposed administration	Reading, by the operator, the host, or a thief
Fails if	An account or device is compromised	The user loses the vault password
Verifiable by	Port scans and connection logs	Opening the storage folder and seeing only .c9r blocks

Honest limit: Tailscale is private, not public. Real users still reach the service over HTTPS on the public node. The tailnet is for operators, nodes and invited testers. Tailscale Funnel can publish a service publicly for a short demonstration.

5. The challenges I faced, and how I solved them

Challenge	How I solved it
Tooling friction. The older Termius build on the Mac had no visible key manager, and the server was not on the default SSH port, so standard tutorials did not apply.	Generated the Ed25519 key directly in the macOS Terminal with ssh-keygen , and used the custom port 52156 explicitly in every command. Both problems became deliberate security choices.
The iPhone Files app refused to connect to the server. I expected to type an address and browse files.	Discovered that the Files app only speaks SMB, not SSH or SFTP, and that AFP is retired. The fix was a design decision: give the Files app an SMB or file provider route, and keep SSH for administration.
The private node only worked on my own Wi Fi. Addresses like 192.168.1.11 are private and cannot be reached from outside, and opening router ports would have been reckless.	Joined both nodes and the phone to a Tailscale tailnet . The home Mac now has a stable 100.x.y.z address and is reachable from anywhere with no ports opened. The public node's SSH port could then be closed to the internet, which reduced the attack surface instead of increasing it.
Cryptomator looked broken, twice. First I saw a photo on my laptop and assumed encryption had failed, then I discovered another photo had been saved next to the vault instead of inside it.	Learned that a vault protects data from the storage and from other people, not from the key holder, and that files are only protected when they are inside the vault. Verified it by opening the storage folder without unlocking and seeing scrambled names only.
The vault worked, but I had no way to prove privacy to anyone.	Built a repeatable demonstration: encrypt on the device, then show the storage folder and display only unreadable blocks. Proof beats a promise in front of judges.
Terminology was overwhelming. Encryption, TLS, SMB, SFTP, NAT, WireGuard, federation.	Wrote a bilingual glossary as I learned, so the concepts became usable rather than intimidating. It is now a companion document to this report.
The first network map looked wrong and put Riyadh at the centre. It undermined the idea of decentralisation.	Rebuilt the map from real province level geographic data, placed twelve equal peer nodes with no hub, and verified every node sits inside its own region.
Choosing an architecture. SMB, SFTP, a cloud platform, or all three, and then how to secure it.	Settled on a layered design: a public node for users over HTTPS, a private node for capacity, one tailnet joining them for administration and federation, and Cryptomator for the contents.

6. Why Sandooq is better than iCloud

	iCloud	Sandooq
Who can read your files	Apple holds the keys. You trust a policy.	Only you. The key never leaves your device.
Where your files live	Data centres abroad.	Inside Saudi Arabia.
Can you verify privacy	No. You take their word.	Yes. The disk shows unreadable encrypted blocks.
What you pay	A subscription, forever.	A free tier, then plans priced below mainstream providers.
Who earns from your storage	A foreign corporation.	Saudi hosts, families and small businesses.
Economic effect	Money, data and skills leave the country.	Money, data and skills stay in the Kingdom.

In one line: iCloud rents you space on someone else's computer. Sandooq gives you encrypted space on infrastructure you and your neighbours own, and pays those neighbours for it.

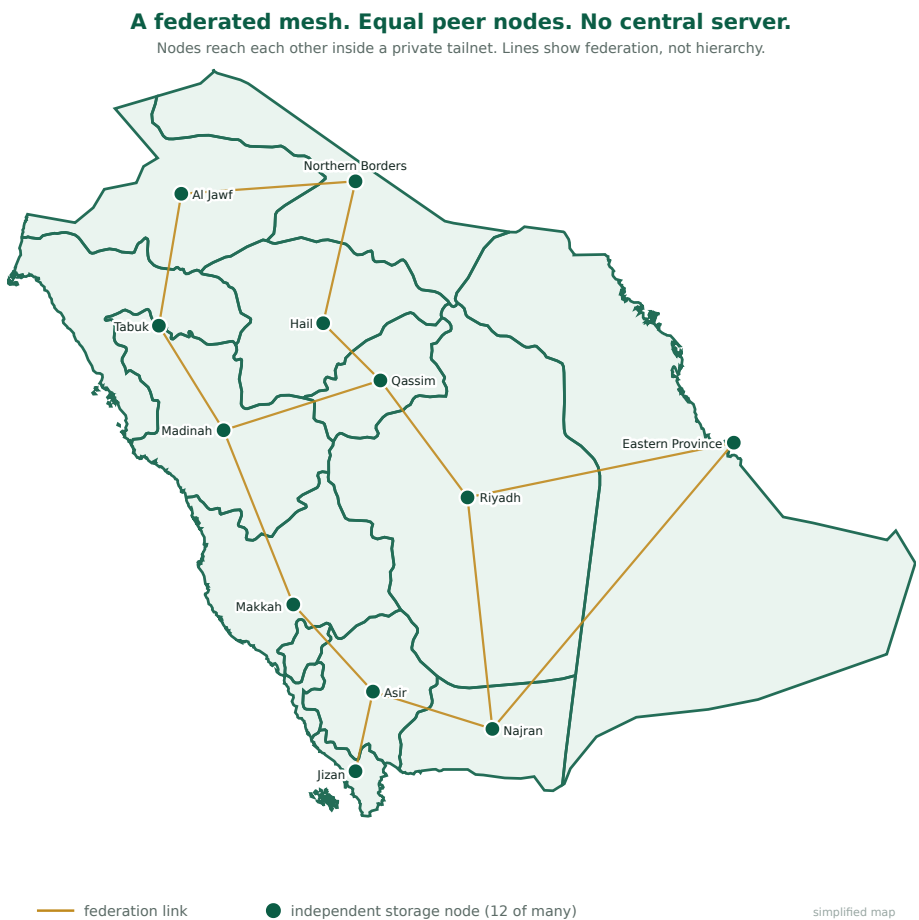
7. The core idea: a marketplace, not just a server



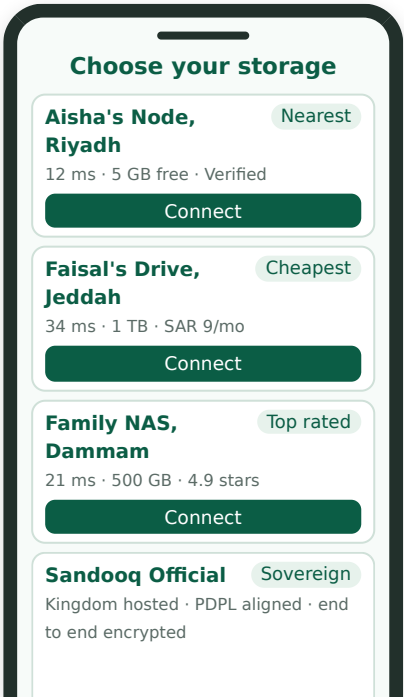
1. **Install the host app** on a computer or NAS and connect it to Sandooq.
2. **Declare capacity and availability**, and pass a readiness check for uptime, encryption and speed.
3. **Go live**. The node appears in the app with its price, latency and trust signals.
4. **Serve users and get paid**. The node stores encrypted blocks it cannot read and receives a monthly payout for the space actually used. The private node reaches the network over the tailnet.

8. A federated mesh across the Kingdom

Sandooq is not one central server with smaller servers attached. It is a mesh of equal peer nodes, each independently operated, joined through federation. Nodes reach each other inside a private tailnet rather than over the open internet, which makes the mesh both decentralised and quiet: there is no centre, and there is nothing for a stranger to scan.

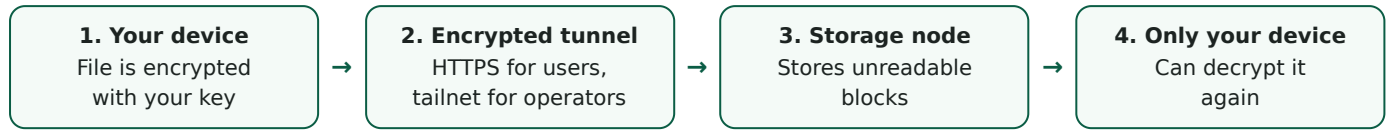


Every dot is a node an independent operator can run, from a student with one external drive to a small business with a rack. The lines are federation links, not a hierarchy. Users choose by price, latency and trust, and are never locked to one operator.

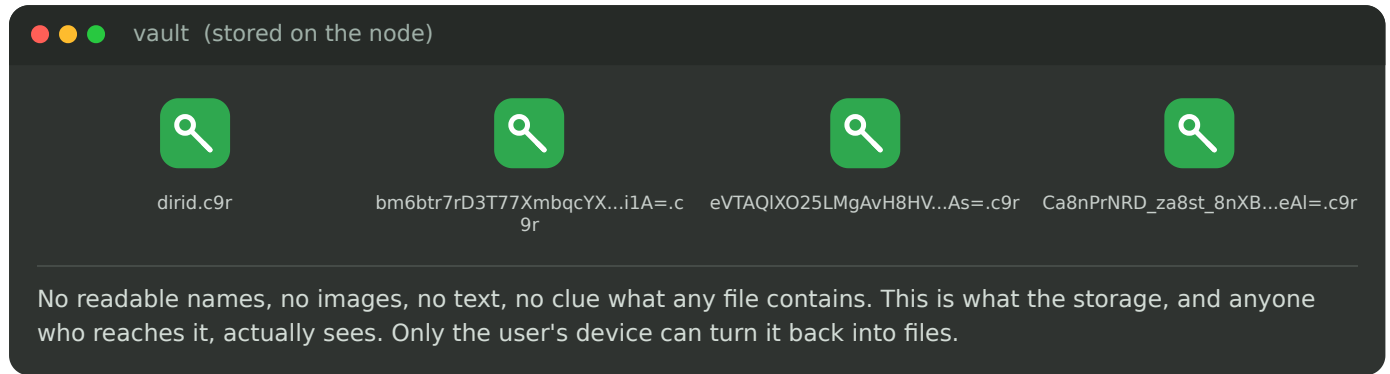


Connect

9. Privacy, cryptographically



This is the actual content of the vault on the storage:



Who	Can read the files?	What they can see
The user	Yes , they hold the key	Everything they own
Node operator or host	No	Encrypted blocks, file counts, rough sizes, activity
Port scanner on the internet	Nothing to reach	HTTPS on the public node only, no administration ports
Other users	No	Only what is explicitly shared
Network eavesdropper	No	Scrambled traffic, and operator traffic is inside the tailnet
Thief with the disk	No	Unreadable storage

Stated plainly: a host can still observe metadata, and anyone controlling a disk can always delete data. What no one can do is read it. That claim is testable, and users are invited to test it.

10. The economics

Item	Example
Host offers	500 GB on an idle external drive
Used in month one	40% = 200 GB rented
Market price	SAR 10 per 100 GB per month
Gross revenue	SAR 20 per month
Platform commission (20%)	SAR 4
Host payout	SAR 16 per month , from hardware that was earning nothing

Illustrative figures. They show the shape of the model, not a promise of income.

Today: a subscription to a foreign provider

100% leaves the Kingdom

Sandooq: the same payment, redistributed locally



● stays with Saudi hosts ● platform commission ● leaves the country

Potential business model

Stream	How it works
Subscriptions	A free starter tier, then paid plans in SAR priced below mainstream providers.
Marketplace commission	A percentage of every rental between a user and a host, growing automatically with the network.
Family and group plans	A shared pool for families and friend groups: one payer, many users.
Schools and small businesses	Private, PDPL aligned storage with data residency in the Kingdom.
Managed hosting and white label	Setup and maintenance of nodes for organisations, and licensing to local brands and ISPs.

11. Market, rollout and risks

First users: students with full phones and no budget, families with scattered photos, privacy focused users, small businesses that need local storage, and hosts who want their idle hardware to pay for itself.

Channels: short form video that shows a photo turning into unreadable data; campus ambassadors; gaming and creator communities; national technology events such as LEAP and SDAIA initiatives; device retailers and ISPs as host onboarding points; a referral programme; and plain Arabic and English education content.

Phase	Goal
0. Proof of concept (now)	Two nodes joined by a tailnet, HTTPS for users, accounts, quotas, an encrypted vault, and a host rental demo.
1. Private pilot (1 to 3 months)	10 to 30 testers invited into the tailnet, onboarding, backups, monitoring.
2. Multi user product (3 to 6 months)	Self service signup, two factor, mobile apps, billing, support.
3. Federation (6 to 12 months)	Multiple nodes federating over the tailnet, a node directory, and the in app node picker.
4. Market launch (12 to 18 months)	Host app, reputation, payouts, commission.
5. Scale (18 months and beyond)	A national network, B2B and white label, partnerships, compliance programme.

Risk	Response
Exposed administration	SSH closed to the internet and reached only inside the tailnet, so scanners have nothing to attack.
Security attacks	HTTPS everywhere, key only SSH, updates, firewall, two factor, least privilege, per device access rules.
Abuse and data loss	Clear terms, account limits, a take down process, and backups in a second location with tested restores.
Untrustworthy hosts	End to end encryption removes the ability to snoop; verification tiers and public reputation manage reliability.
Regulation	In Kingdom hosting, documented policy, minimal metadata, and clear consent under PDPL.

Sandooq. Storage you own. Privacy you can verify. Income that stays in the Kingdom.

Saudi based, self hosted and encrypted end to end, administered over a private Tailscale network, and built so that the people who provide the storage are the people who earn from it.